# SafeFlow 安全自评报告

权限分级实现 已知风险与验证边界
2026年10月31日演示版

## 自评对象与安全目标

本报告说明 SafeFlow 2026年10月31日演示版的权限分级、AI 风险防护、交易安全与已知风险。结论是：系统已设置模型之外的执行约束并有相应功能验证，可用于隔离模拟业务演示；本报告属于项目自评，不是第三方渗透测试、金融合规认证或生产银行安全证明。

### 评估范围

范围包括 GitHub Pages 公开介绍、Netlify 银行前端、Rust API 与后台任务、PostgreSQL 业务存储、审计发送及接收流程。业务使用虚构身份和模拟资金；评委共用 user_001 演示账户。真实银行接入、真实通知渠道、生产级个人认证和可信外部存证不在本次已验证范围。

### 需要保护的对象

| 对象 | 保护目标 |
| --- | --- |
| 资金与卡状态 | 未经当前有效确认与许可不发生写入；冻结限制在最终事务仍被检查。 |
| 账户和交易资料 | 按可信会话与本人范围读取，防止跨账户或伪造标识访问。 |
| 确认与执行记录 | 绑定任务、操作、参数版本和期限，避免旧确认错用于新操作。 |
| 模型与数据库凭据 | 仅在服务端私有配置使用，不放入页面、前端包或公开下载。 |
| 审计事件和回执 | 持久化、去重、摘要校验和严格回执匹配，便于恢复与追溯。 |

### 威胁假设

不信任用户文本、浏览器存储、模型输出、前端声称的角色和外部业务文字。考虑误理解、提示注入、越权标识、重复点击、旧页面回放、网络超时、服务重启、并发写入及事件传输失败。系统不能仅依赖页面禁用按钮或提示词保证安全。

# 权限分级及实现

权限分级落实为会话、身份、用途、工具、操作和期限等检查，而不是由模型在回复里宣称“已获授权”。下表描述实际职责边界，不代表已经上线独立管理员控制台。

## 主体与能力

| 主体 | 允许能力 | 边界 |
| --- | --- | --- |
| 未登录访问者 | 阅读介绍和使用指南 | 不能查询本人账单或执行银行写操作。 |
| 演示用户会话 | 读取本人资料，准备与确认对应业务 | 共用演示身份；不能自行变更账户归属或增加收款目录。 |
| 模型规划器 | 提出允许工具的结构化计划或澄清 | 无数据库、解冻、充值或任意外部调用权。 |
| 后端业务执行 | 在身份、安全裁决、确认和许可均有效时执行 | 最终事务重核来源、状态和并发条件。 |
| 独立付款后台 | 在已明确委托的单笔原单上继续处理 | 单笔30分钟及部署身份期限约束；不替用户确认。 |
| 管理与运维入口 | 按私有受控入口管理演示运行和模拟余额 | 不提供前端或模型充值；管理调整有独立凭证。 |
| 审计发送与接收 | 传递及保存原事件，返回严格回执 | 普通用户无 raw 审计或数据库权限；回执不授予付款权。 |

## 有界确认和许可

初始确认5分钟，模拟验证最长2分钟，单次执行许可60秒；改办后草案沿既有10分钟期限，不能据此延长付款权。后台须另行明确委托，有效30分钟；登出不自动撤销，主动撤销或到期停止续办。已经受理但状态未知的原单继续核查，不能自动清占用。

## 归属与资源约束

后端从可信会话取得本人身份，并核资源所属及真实来源版本；客户端参数只是选择，不能授予归属。当前公开演示只配置一个可选收款人李明远（尾1024），不接受聊天新增任意真实账户。

# AI 幻觉与提示注入防护

防护目标是降低错误内容转化为越权执行或虚假业务结论的机会。模型仍可能误解、拒答或超时，因此自评不使用“零幻觉”“绝对安全”等不可证承诺。

## 多层防护与触发行为

| 风险 | 防护实现 | 系统应有的反应 |
| --- | --- | --- |
| 编造收款人或账号 | 可信本人目录和资源标识校验 | 不能映射时追问或拒绝准备。 |
| 编造工具或危险参数 | 工具注册表、Schema和计划校验 | 拒绝未知工具、额外字段和不匹配版本。 |
| 要求忽略规则或扮演管理员 | 文本不可信，权限从会话和后端配置取得 | 聊天声明不增加权限，仍走原确认流程。 |
| 用旧确认执行新金额 | 绑定参数快照、任务版本、操作与期限 | 要求核对新草案并重新确认。 |
| 谎称付款已完成 | 页面根据实际工具及持久结果呈现 | 保存草案、处理中和成功分别显示。 |
| 模型要求验证码或秘密 | 验证码在业务表单手动输入；秘密不下发 | 使用说明要求不向聊天发送码或真实银行卡资料。 |

## 关键写操作由程序控制

模型不能替代付款、冻结或订阅变更的明确确认；模拟验证码须用户手动填写原验证表单。付款和卡片的验证码及授权不共用。最终事务再次核对卡锁、余额、确认、许可与原单，防止仅凭模型一段正确格式的输出执行资金写入。

## 输出与供应商边界

协议约束模型输出计划或澄清，不凭模型文字生成资金成功结论。必要上下文会发给指定模型供应商，评委应只输入虚构测试资料。系统未给出幻觉率、攻击防御成功率或模型性能领先的统计结论；现有测试不能穷尽所有提示注入变体。

# 交易一致性与运行安全

交易安全既要阻止不允许的动作，也要在超时、断网和重启后保留真实结果。前端显示失败不构成资金未执行的证明。

## 资金安全

金额按明确单位校验；创建草案、付款确认、后台委托、验证、许可与完成分阶段记录。最终事务重核归属、收款映射、余额和冻结状态。同号重投沿原结果恢复，不再次扣款。只有证据证明未进入资金受理的草案才可结束，真实资金未知结果不会因新任务或计时被清除。

## 会话和网页防护

银行交互采用 HTTPS、HttpOnly/Secure/SameSite 会话 Cookie、Origin 与 CSRF 校验，并对业务响应使用 no-store。前端提供 CSP 等安全策略，公开 Pages 使用静态内容和 meta CSP；meta 不等于提供所有 HTTP 响应头。模型凭据和数据库凭据通过受限服务端配置提供，公开资料不含登录口令。

## 审计与恢复

业务结果与 Outbox 同事务保存，发送器重投原事件并核严格 ACK。接收侧校验事件、去重、持久化并核摘要；发送失败保持可恢复状态，不手填回执。接收器具有本地哈希链和本地签名检查点能力；本轮线上逐项核对新增事件与 ACK，未另做全链重算、检查点或可信外锚点验证，不把链上存证作为本次安全通过项。

## 版本与变更控制

产品实现、自测、指定独审和实际部署分工执行，按固定版本核对源码与发布资产。余额调整另记差额凭证，不改旧 opening 和历史流水。维护44及新增调整账本生效后，不能通过回盖旧资金程序或删除账本作回退。

## 本轮实际检查

草案结束与历史恢复的新差异已指定独审限定通过，完整桌面手机流程得到覆盖；实际部署102件证据已核收。本轮两条非资金结束和一条余额调整事件均收到逐项匹配的严格回执。线上未代评委执行新付款、冻结或解冻，未将未执行项目写为通过。

# 已知风险与自评结论

以下内容是比赛提交要求中的已知风险清单，说明当前可接受的演示边界及进一步应用的条件，不将模拟环境包装成生产银行服务。

## 已知风险清单

| 风险或限制 | 当前控制 | 适用条件 |
| --- | --- | --- |
| 评委共用身份与持续状态 | 私下发口令，提示操作保留、不自动重置 | 无法据此区分每位评委；不得当作真实客户账户。 |
| 同设备显示模拟验证码 | 绑定操作且手动输入，与确认分开 | 用于流程演示，不等于短信或银行强认证。 |
| 冻结卡影响后续付款 | 最终事务仍拦截，不自动解冻 | 当前6628已冻结，无网页自助解冻；成功付款需另备合格前置。 |
| 模型错误与外部依赖 | 来源约束、独立校验、澄清和原结果恢复 | 不能保证每次模型理解正确或供应商持续可用。 |
| 订阅服务外部效果 | 明确本地意图和模拟提醒状态 | 不构成真实商户退订或外部通知送达。 |
| 本地审计与可信外部证明 | 哈希、去重、严格回执和检查点 | 尚无本次通过的可信外锚点或链上存证证明。 |
| 公网演示运行期限 | 身份有界，私有运维入口与恢复记录 | 现有身份至北京时间11月11日零点；后续需组织者安排。 |

## 验证边界

前端测试、事务与恢复测试、独审和线上限定核验分别提供证据。本自评未宣称完成第三方全面渗透、全部并发负载、全部灾难恢复、供应商内部安全或生产级多用户认证验证。历史局部通过不扩大为全项目安全放行。

## 结论与责任

在虚构资料、私下口令、逐笔明确确认和有界权限的前提下，现有系统可用于评委体验银行 Agent 的对话、安全执行及恢复方法。公开页面只展示必要信息；真实应用前，组织者和相应业务提供方仍须按真实身份、认证、通知、运行与存证条件分别验证。